

AI Logging Requirements

What to log, where it goes, and what the SOC must be able to do

You cannot detect, investigate, or prove anything about an agent you did not log. AI logging is where a SOC background pays off: the goal is not just capturing text, but capturing enough to reconstruct *what the agent did and why* — and to feed the SIEM so misuse is detectable in near-real-time. This is the Observability & SOC domain: Identify, Detect, Respond.

What to log

Every agent interaction should produce a structured, correlatable record. At minimum:

Field	Why it matters for detection & IR
Prompt	The full input, including retrieved/tool content — the injection evidence.
Response	What the agent said or decided; needed to spot data leakage and unsafe output.
Tool calls	Which tool, which parameters, what result — the action trail.
Decision / approval	What was gated, approved, or denied, and by whom.
Identity & user	The agent's identity and the acting user — attribution for IR.
Model & version	Model, version, and prompt/config version for reproducibility.
Timestamp & session	Correlation across a multiturn session — catches slow, staged attacks.
Errors & refusals	Guardrail triggers and failures — often the first sign of probing.

Where it goes

Application telemetry (e.g. Application Insights) → central log store → SIEM (e.g. Microsoft Sentinel), where detections and playbooks live. Logs must be tamper-evident and retained per policy. The pipeline is what turns "we log things" into "the SOC can act."

Capability	What the SOC should be able to do
Identify	Enumerate every agent, its identity, and its normal behavior baseline.
Detect	Alert on injection patterns, anomalous tool use, unusual data access, repeated refusals.
Respond	Trace an incident end-to-end, attribute it, and trigger the kill switch / revoke access.

Framework mapping

Logging and monitoring map to: **NIST AI RMF (Manage)**; **SOC 2 CC7 (system monitoring)**; **ISO/IEC 42001** and **ISO/IEC 27001**; and **EU AI Act Art.12 (record-keeping / logging)** for high-risk systems. Intent-based monitoring — watching what the agent is *trying* to do, not just individual calls — is the maturity target.

Reviewer's quick checklist

- Prompts (incl. retrieved/tool content), responses, and tool calls are logged.
- Decisions, approvals, denials, and guardrail triggers are captured.
- Agent identity and acting user are recorded for attribution.
- Model, version, and prompt/config version logged for reproducibility.
- Sessions are correlatable across multiturn interactions.
- Logs flow to the SIEM; detections exist for injection and anomalous tool use.
- Logs are tamper-evident, retained per policy, and IR can trace an incident end-to-end.

Safety. Use safe sample data only. Never use real credentials, tokens, or customer data, and never test production systems. Any dynamic probing runs only against an explicitly authorized lab or staging environment, and all results are labeled as authorized testing.